

Chirag

A Fully Local, Citation-Aware RAG for Cryptography

Retrieval-Augmented Generation over RFCs, NIST Standards, and Cryptanalysis Papers

Halil Kaplan

October 2, 2026

Fully local pipeline — embeddings + generation run on your own machine

The problem: LLMs hallucinate on precise technical questions

Question: What is the data complexity of Matsui's linear cryptanalysis attack on 16-round DES?

Answer (plain LLM, no grounding): “The data complexity is approximately 2^{50} to 2^{53} plaintext-ciphertext pairs . . . some sources cite values as low as 2^{47} or as high as 2^{53} , but 2^{50} is the most commonly referenced estimate.”

- The real value is 2^{43} known plaintexts (Matsui 1993) — a factor of 2^7 – 2^{10} off.
- In cryptanalysis an exponent decides whether an attack is practical (. . . and no source is given for the wrong numbers).
- LLMs are excellent assistants — except when they make things up.

The problem: LLMs hallucinate on precise technical questions

Question: What is the data complexity of Matsui's linear cryptanalysis attack on 16-round DES?

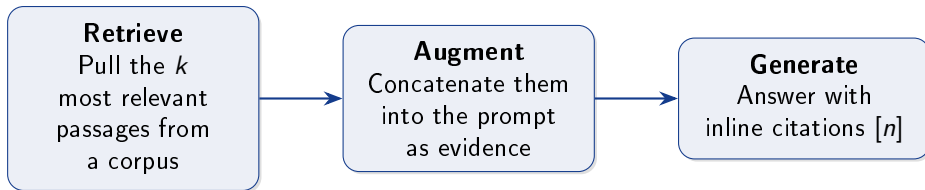
Answer (plain LLM, no grounding): "The data complexity is approximately 2^{50} to 2^{53} plaintext-ciphertext pairs ... some sources cite values as low as 2^{47} or as high as 2^{53} , but 2^{50} is the most commonly referenced estimate."

- The real value is 2^{43} known plaintexts (Matsui 1993) — a factor of 2^7 – 2^{10} off.
- In cryptanalysis an exponent decides whether an attack is practical (... and no source is given for the wrong numbers).
- LLMs are excellent assistants — except when they make things up.

Idea

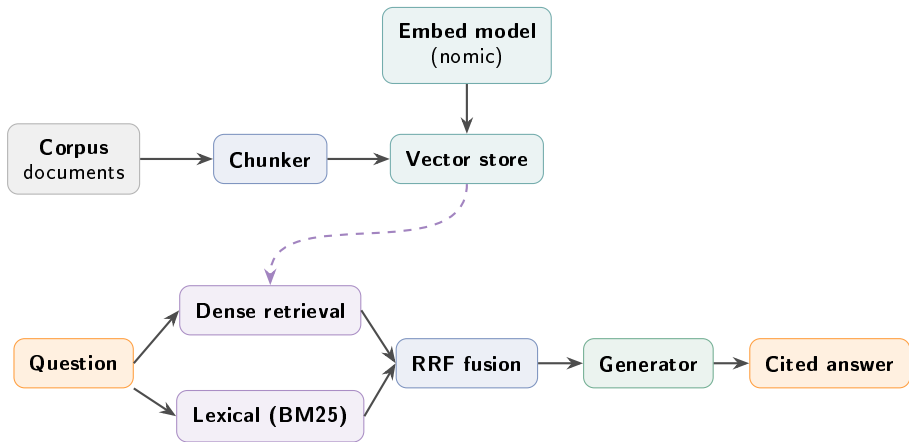
Give the model *evidence* every time it answers, and force it to cite that evidence inline. This is **Retrieval-Augmented Generation (RAG)**.

What is RAG?



- The answer is *grounded* in retrievable, auditable documents.
- Wrong/hallucinated facts can be traced back to a source.
- The corpus is *curated* for the domain — here: cryptography.

How a RAG pipeline works



Dense embeddings capture *semantics*; BM25 captures *exact identifiers* (2⁴³, “RFC 8446”). Reciprocal-rank fusion combines both.

Why RAG (and why fully local)?

Why RAG

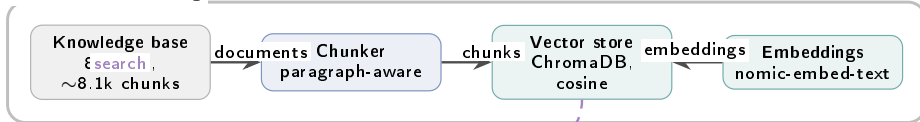
- **Grounding:** every claim backed by a retrieved document
- **Inline citations:** [SOURCE n: title] — auditable
- **Controlled corpus:** standards, RFCs, papers, private docs
- **Up-to-date:** swap corpus, no retraining

Why local

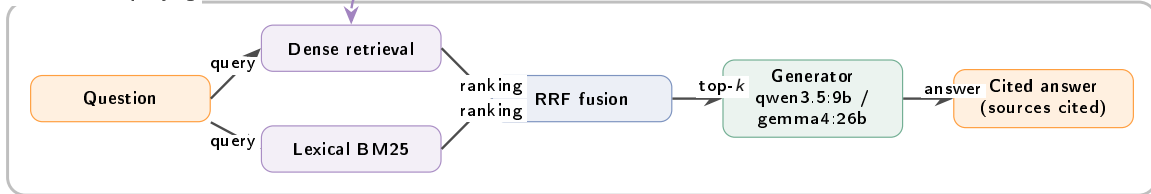
- Real crypto work is *confidential* — nothing leaves the machine
- Embeddings & generation via Ollama on consumer GPU
- No API cost, no rate limits, fully reproducible
- Works offline (air-gapped environments)

Chirag architecture

OFFLINE — indexing



ONLINE — querying



Every component is an isolated Python module and can be swapped for ablations or other deployments. All models run locally via Ollama.

82 documents, ~8,100 chunks

- **22 IETF RFCs** — TLS 1.2/1.3 (8446), RSA-PKCS#1 (8017), HPKE, HKDF, SSH, X.509, AEAD (5116), Ed25519, ChaCha20-Poly1305, BLAKE2
- **26 NIST standards** — FIPS 197 (AES), FIPS 202, SP 800-38D (GCM), SP 800-56, SP 800-57, DRBG, ML-KEM/ML-DSA, SP 800-90/107/131/185/186...
- **34 landmark papers** — Biham & Shamir, Matsui, Bleichenbacher, Coppersmith, Kocher (DPA), Vaudenay, Wagner, Wang et al. ...

Doc-type classification

- Attack-related keywords → cryptanalysis paper
- NIST/FIPS filenames → standard
- RFC filenames → RFC

Metadata per document

source, title, url, type

Hybrid retrieval: dense + lexical + RRF

- **Dense:** nomic-embed-text (768-dim) in ChromaDB with cosine similarity — finds *semantic* matches.
- **Lexical:** Okapi-BM25 over the whole corpus — catches *exact identifiers*: “RFC 8446”, “2⁴³”.
- **Fusion:** reciprocal-rank fusion of both rankings — robust to incomparable score scales.

<i>k</i>	dense			hybrid		
	hit@ <i>k</i>	MRR@ <i>k</i>	nDCG@ <i>k</i>	hit@ <i>k</i>	MRR@ <i>k</i>	nDCG@ <i>k</i>
1	.796	.796	.796	.735	.735	.735
3	.898	.847	.847	.918	.820	.839
5	.959	.861	.883	.939	.824	.851
10	.959	.861	.883	.980	.830	.865

49-Q benchmark; hybrid hit@10 = 0.980.

A hallucination-guard prompt

The generator sees each distinct document as SOURCE *n* and is instructed to:

- 1 Answer **only** from the retrieved context; never invent papers, RFCs, standards or results.
- 2 Attach an inline citation [SOURCE *n*: title] to *every important claim*.
- 3 **Never** cite a source number that is not in the context.
- 4 Reproduce concrete parameters (rounds, data/time complexity, key sizes) exactly as reported.
- 5 If the context covers only part of the question, answer that part and say what is not covered.

A hallucination-guard prompt

The generator sees each distinct document as SOURCE *n* and is instructed to:

- 1 Answer **only** from the retrieved context; never invent papers, RFCs, standards or results.
- 2 Attach an inline citation [SOURCE *n*: title] to *every important claim*.
- 3 **Never** cite a source number that is not in the context.
- 4 Reproduce concrete parameters (rounds, data/time complexity, key sizes) exactly as reported.
- 5 If the context covers only part of the question, answer that part and say what is not covered.

Result on the benchmark (15 answers, qwen3.5:9b)

- mean LLM-judged faithfulness (1–5): **4.07**
- answers with ≥ 1 cited line: **14/15**
- judged by an *independent* model (gemma4:26b) against gold sources — no self-scoring bias

Three ways to use Chirag

Terminal UI (TUI)

- Full-screen chat (Textual), streaming, markdown + citations
- Multi-turn memory, model switcher, doc-type filter
- Document browser with live search & delete

HTTP API

- REST: /api/query, ingest, stats, summarize
- OpenAI-compatible: /v1/chat/completions — usable from opencode, curl, any app

CLI

```
'chirag' # TUI
'chirag query' "Matsui's 16-round DES attack?"
'chirag ingest-rfc 9180'
'chirag summarize' RFC 8446
'chirag eval -answer 15'
  '-judge'
'chirag serve'
```

Models are config-driven (opencode-style JSON): every

Ollama model + any OpenAI-compatible provider, switchable on the fly.

Retrieval

- 49-question grounded benchmark with gold sources
- $\text{hit}@k$, $\text{MRR}@k$, $\text{nDCG}@k$ for $k \in \{1, 3, 5, 10, 20\}$
- dense vs. hybrid (RRF) comparison

Answer quality

- Same 49 questions; generate answers with qwen3.5:9b
- Independent judge gemma4:26b scores faithfulness (1–5) against gold source text

metric	value
benchmark questions cat. (subset)	49 sym-cryptanalysis, asymmetric, hash, post-quantum, side-channel, protocols, rng, theory
mean faithfulness	4.07 / 5
answers w/ citations	14 / 15
mean cited-line rate	0.47

Live comparison: same question, same model — with vs. without RAG

Question: What is the data complexity of Matsui's linear cryptanalysis attack on 16-round DES?

RAG with retrieval

faith 5/5

*"Matsui's linear cryptanalysis attack on full 16-round DES has a **data complexity of about** 2^{43} **known plaintexts** [SOURCE 1: Linear Cryptanalysis Method for DES Cipher (Matsui 1993)] ... 8 rounds: $2^{21.5}$, 12 rounds: 2^{33} ." (verbatim, abridged)*

exact parameters, all source-cited; contextualizes variants (8/12 rounds).

No RAG, no context

faith 1/5

"The data complexity is approximately 2^{50} to 2^{53} plaintext-ciphertext pairs ... Some sources cite values as low as 2^{47} or as high as 2^{53} , but 2^{50} is the most commonly referenced estimate." (verbatim, abridged)

wrong by 2^7 – 2^{10} in the exponent; no source at all.

Same generator (qwen3.5:9b), same temperature — the only difference is retrieved evidence + citation guard.

Live comparison: differential cryptanalysis on 16-round DES

Question: How many chosen plaintexts are required to break 16-round DES using differential cryptanalysis?

RAG with retrieval

faith 5/5

*"According to Biham and Shamir's 1991 work on differential cryptanalysis of DES-like cryptosystems, **full 16-round DES can be broken with 2^{47} chosen plaintexts (2^{47} encryptions)** using differential cryptanalysis [SOURCE 1: Differential Cryptanalysis of DES-like Cryptosystems (Biham, Shamir 1991)]."* (verbatim, abridged)

concrete, correct, cited.

No RAG, no context

faith 0/5



no answer produced — the model spent its token budget and returned empty without retrieved context.

unusable answer for this question.

Grounding does not only improve answers — it makes the assistant usable where the ungrounded model fails entirely.

RAG vs. no-RAG on the evaluation corpus (15 questions)

	RAG	no-RAG
mean LLM-judged faithfulness (1–5)	2.33	1.87
answers containing ≥ 1 citation	14 / 15	0 / 15
correct attack parameters (Matsui, Biham-Shamir)	correct + cited	wrong / empty
retrieval: hybrid hit@10 (49 Q)	0.980	—
answer faithfulness distribution	12×5, 1×1, 2×0	...

Key take-aways

- RAG converts *confident hallucination* into *grounded, cited* answers.
- The whole pipeline is local and open source — private by design.
- A curated, swappable corpus (RFCs, standards, papers) is what makes it useful for cryptography.

- **Chirag** is a fully local, citation-aware RAG system for cryptography and cryptanalysis.
- Hybrid retrieval (dense + BM25 + RRF) reaches **hit@10 0.980** on a 49-question benchmark.
- A hallucination-guard prompt yields cited, grounded answers — the same model without retrieval produces wrong parameters and zero citations.
- Practical interfaces: TUI, CLI, and an OpenAI-compatible HTTP API.
- Repository includes the full pipeline, benchmark, eval harness, and the accompanying paper (paper/).

Questions?